

SGSI-UNCP

Matriz de Evaluación y Plan de Tratamiento de Riesgos

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Matriz de Evaluación y Plan de Tratamiento de Riesgos
 - 1.1 Evaluación de Riesgos
 - 1.2 Plan de Tratamiento de Riesgos
 - 1.3 Resumen de Riesgos por Nivel
 - 1.4 Seguimiento y Actualización

1. Matriz de Evaluación y Plan de Tratamiento de Riesgos

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Metodología:** D-SGSI-04 (NR = O + I) **Criterio de Aceptación:** NR ≤ 4 (Bajo)

1.1. Evaluación de Riesgos

ID	Activo Afectado	Amenaza	Vulnerabilidad	O	I	NR	Nivel	Opción de Tratamiento
R01	ERP ADESA (BD Matrícula, Notas)	Inyección SQL / manipulación de datos	Código legado no auditado, sin WAF, sin parametrización de consultas	2	4	8	Medio	Mitigar
R02	Campus Virtual (Moodle 4.1)	Ransomware / cifrado de datos	Falta de backups inmutables, versión de plugins desactualizada	2	4	8	Medio	Mitigar
R03	Centro Médico (HC digitales)	Acceso no autorizado a datos sensibles (Ley N.º 29733)	Falta de MFA, autenticación por usuario y contraseña únicamente	3	4	12	Alto	Mitigar
R04	Red LAN de Facultades	Sniffing / interceptación de tráfico	Tráfico interno no cifrado, segmentación de red insuficiente	3	3	9	Alto	Mitigar
R05	Storage NAS (Backups)	Falla de hardware / pérdida de respaldos	Disco único sin RAID, falta de replicación off-site	2	4	8	Medio	Mitigar
R06	Microsoft 365 (Correo)	Phishing dirigido / suplantación de identidad	Falta de capacitación en seguridad, ausencia de DMARC/DKIM avanzado	3	3	9	Alto	Mitigar
R07	Huawei Cloud	Configuración incorrecta de IAM / exposición de datos	Falta de revisión periódica de accesos cloud, ausencia de Cloud Security Posture Management	2	4	8	Medio	Mitigar
R08	DSpace (Repositorio)	Pérdida de propiedad intelectual / plagio	Control de acceso básico sin registro de descargas, ausencia de DRM	2	3	6	Medio	Mitigar
R09	Personal OTI (2 profesionales)	Error humano / mala configuración	Personal insuficiente para ~11,700 usuarios, alta carga laboral, sin segregación de funciones	3	3	9	Alto	Transferir
R10	Sistema GESDOC	Denegación de servicio (DDoS)	Sin CDN, sin protecciones anti-DDoS, ancho de banda limitado	2	3	6	Medio	Mitigar

ID	Activo Afectado	Amenaza	Vulnerabilidad	O	I	NR	Nivel	Opción de Tratamiento
R11	Servidor ADESA (HW-001)	Corte eléctrico prolongado	UPS con autonomía limitada (30 min), sin generador eléctrico de respaldo	2	4	8	Medio	Mitigar
R12	Portal Web (WordPress)	Defacement / suplantación institucional	Plugins sin actualizar, sin WAF, sin monitoreo de integridad de archivos	2	3	6	Medio	Mitigar
R13	VPN Corporativa	Acceso no autorizado desde equipos personales	Sin control de dispositivos (BYOD), sin MFA obligatorio	2	4	8	Medio	Mitigar
R14	SIGA/SIAF (RRHH, Planillas)	Fuga de datos personales de trabajadores	Acceso privilegiado sin auditoría, datos personales sin cifrar	2	4	8	Medio	Mitigar
R15	Sede Desconcentrada (Filial)	Robo de equipos / pérdida de información	Sin inventario actualizado de activos, sin cifrado de discos	3	3	9	Alto	Mitigar

1.2. Plan de Tratamiento de Riesgos

ID	Controles ISO 27001:2022	Acción de Tratamiento	Responsable	Fecha Límite	Estado	NR Residual
R01	A.8.25 (Desarrollo Seguro), A.8.20 (Seguridad Redes)	Implementar WAF (ModSecurity), auditar código legacy, migrar a consultas parametrizadas	OTI (Desarrollo)	Q3-2026	Pendiente	4 (Bajo)
R02	A.8.13 (Copias de Seguridad), A.8.8 (Gestión de Vulnerabilidades)	Activar Cloud Backup inmutable en Huawei Cloud con retención de 30 días. Actualizar plugins de Moodle.	OTI (Sistemas)	Q1-2026	En Proceso	4 (Bajo)
R03	A.5.15 (Control de Acceso), A.8.5 (Autenticación Segura)	Implementar MFA vía Keycloak / Microsoft Entra ID para acceso al sistema de salud	OTI (Seguridad)	Q2-2026	Pendiente	6 (Medio)
R04	A.8.20 (Seguridad Redes), A.8.22 (Separación de Redes)	Desplegar segmentación por facultad (VLANs), implementar 802.1X para puertos de red	OTI (Redes)	Q3-2026	Pendiente	4 (Bajo)
R05	A.8.13 (Copias de Seguridad), A.7.10 (Pérdida de Equipos)	Migrar a RAID 6, implementar replicación a Huawei Cloud, probar restauración mensual	OTI (Sistemas)	Q2-2026	Pendiente	3 (Bajo)
R06	A.6.3 (Concienciación), A.8.7 (Protección contra Malware), A.8.20 (Redes)	Campaña de phishing simulada trimestral, habilitar DMARC/DKIM, implementar Microsoft Defender for Office 365	OTI (Seguridad) + Capacitación	Q2-2026	Pendiente	4 (Bajo)
R07	A.5.19 (Proveedores), A.8.29 (Cloud Pública), A.5.22 (Cambios)	Revisión trimestral de roles IAM, implementar CSPM, auditoría de configuraciones cloud	OTI (Cloud)	Q2-2026	En Proceso	4 (Bajo)

ID	Controles ISO 27001:2022	Acción de Tratamiento	Responsable	Fecha Límite	Estado	NR Residual
R08	A.5.32 (Propiedad Intelectual), A.8.3 (Control de Acceso), A.8.15 (Registro)	Implementar registro de descargas por usuario, habilitar DOI, auditar accesos administrativos	OTI (Sistemas) + Investigación	Q3-2026	Pendiente	3 (Bajo)
R09	A.5.3 (Segregación de Tareas), A.6.1 (Antecedentes), A.6.3 (Capacitación)	Contratar 2 profesionales adicionales, externalizar monitoreo SOC, implementar rotación de funciones	DGA / RRHH	Q4-2026	Pendiente	4 (Bajo)
R10	A.8.20 (Redes), A.8.23 (Filtrado Web)	Implementar Cloudflare / CDN, contratar protección anti-DDoS, aumentar ancho de banda a 500 Mbps	OTI (Redes)	Q3-2026	Pendiente	3 (Bajo)
R11	A.7.11 (Infraestructura), A.7.12 (Cableado)	Adquirir generador eléctrico de respaldo (50 KVA), extender autonomía UPS a 2 horas	OTI (Infraestructura)	Q4-2026	Pendiente	4 (Bajo)
R12	A.8.8 (Vulnerabilidades), A.8.7 (Malware), A.8.15 (Registro)	Implementar WAF, monitoreo de integridad de archivos (Tripwire OSSEC), actualizar WordPress y plugins	OTI (Seguridad)	Q2-2026	Pendiente	3 (Bajo)
R13	A.8.5 (Autenticación Segura), A.6.7 (Trabajo Remoto)	Exigir MFA para toda conexión VPN, implementar control de endpoints (NAC), política de BYOD	OTI (Seguridad)	Q2-2026	Pendiente	3 (Bajo)
R14	A.8.2 (Accesos Privilegiados), A.8.11 (Enmascaramiento), A.8.15 (Registro)	Revisar y auditar accesos privilegiados, cifrar datos personales en reposo, implementar PAM	OTI (Seguridad) + RRHH	Q3-2026	Pendiente	4 (Bajo)
R15	A.7.6 (Equipos fuera de instalaciones), A.8.1 (Dispositivos), A.7.10 (Pérdida)	Cifrar discos de todas las laptops (BitLocker/FileVault), actualizar inventario, implementar rastreo GPS	OTI (Sistemas)	Q2-2026	Pendiente	3 (Bajo)

1.3. Resumen de Riesgos por Nivel

Nivel	Rango NR	Cantidad	Acción Requerida
Crítico	13 – 16	0	Acción inmediata del CGD
Alto	9 – 12	5	Tratamiento urgente (máx. 90 días)
Medio	5 – 8	10	Tratamiento planificado (plan anual)
Bajo	1 – 4	0	Aceptado, monitoreo periódico
Total		15	

1.4. Seguimiento y Actualización

- **Próxima evaluación planificada:** Diciembre 2026
- **Responsable del seguimiento:** Oficial de Seguridad y Confianza Digital
- **Frecuencia de revisión:** Trimestral (estado de tratamientos) / Anual (reevaluación completa)
- **Informe a:** Comité de Gobierno Digital (CGD) — Revisión por la Dirección (Cláusula 9.3)

Nota: El Nivel de Riesgo (NR) = Ocurrencia (O) x Impacto (I). NR >= 5 requiere tratamiento documentado. NR <= 4 se considera riesgo aceptable.